

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-49869

Summary

CVE-2026-49869 in Kestra Kestra OSS is being actively exploited in the wild. Kestra is an open-source, event-driven orchestration platform. Prior to 1.0.45 and 1.3.21, AuthenticationFilter in Kestra OSS uses `request.getPath().endsWith("/configs")` to whitelist the public configuration endpoint from Basic Auth. Because the check is a suffix match rather than an exact path match, any API path whose last segment is `configs` bypasses authentication entirely. An unauthenticated remote attacker can exploit this to create and execute arbitrary workflows without credentials. Because Kestra ships with script execution plugins (plugin-script-shell, plugin-script-python, etc.) enabled by default, this directly results in unauthenticated Remote Code Execution as root inside the Kestra worker container. This vulnerability is fixed in 1.0.45 and 1.3.21. CISA requires federal remediation by 2026-09-05; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-49869
- **Affected:** Kestra Kestra OSS
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-02
- **Severity:** CVSS 10.0 Critical, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
- **Exploitation likelihood (EPSS):** 1%
- **Weakness:** CWE-78, CWE-184, CWE-287, CWE-918

Recommended action

Patch CVE-2026-49869 by 2026-09-05. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.